Bsc Software Engineering Group B Group 6

Project 6: Zero-Knowledge Password Manager — Threat Model Executive Summary

System Architecture: Client (Browser Extension) executes all cryptography (Argon2id, XChaCha20-Poly1305, OPAQUE, X25519). Server (Express) operates strictly as a blind relay. Database (PostgreSQL) persists ciphertext exclusively.

Group 6 Team Roster

Name	Index
Stedan Yaw Boah Ampofo	1696596666
Prince Lateef Abdul Rahman	1703675677
Keith Tetteh Yaotey	1694883181
Prince Opoku Owusu	1702131132
Sedoame Kofi Ahorlu	1704464006
Bright Kportiklah	1693948139
Cyril Prince Agbeve	1701864653

Trust Boundaries

ID	Boundary	Components
TB-1	Client Trust Zone	User + Browser Extension
TB-2	App Server Zone	Express Server (Blind Relay)
TB-3	Database Zone	PostgreSQL (Ciphertext)
TB-4	External API Boundary	Have I Been Pwned API

STRIDE Threat Distribution (21 Total Threats)

Spoofing	Tampering	Repudiation	Info Disclosure	Denial of Service	Elevation of Priv.	Total
3	**4**	**2**	**4**	**3**	**5**	**21 Threats**

Top 5 Critical Threats & Primary Architectural Controls

ID	Threat Description	Severity	Architectural Control / Mitigation
T-07	Master password theft via DOM injection / XSS	**Critical**	Isolated Manifest V3 execution contexts + strict Content Security Policy (CSP)
T-03	Bit flip in stored vault ciphertext	**Critical**	XChaCha20-Poly1305 AEAD integrity authentication & cryptographic tags
T-08	Full DB dump and server log theft	**Critical**	Zero-knowledge architecture; server and DB persist ciphertext exclusively
T-09	HIBP hash disclosure during breach check	**Critical**	5-character prefix SHA-1 k-anonymity protocol (zero full hashes transmitted)
T-14	Phishing via browser frame impersonation	**Critical**	Exact-origin matching via webNavigation API + user gesture requirement

Residual Risks (3 Items)

1. Metadata leakage (sync frequencies, payload sizes, IP addresses).
2. Compromised client OS (kernel keyloggers can capture master password).
3. Unrecoverable password loss (no server-side reset possible under zero-knowledge).

Deliverable Verification Checklist (6 Items)

- [✓] Level-1 DFD authored in OWASP Threat Dragon
- [✓] 4 trust boundaries marked (TB-1 to TB-4)
- [✓] 21 STRIDE threats recorded across all 6 categories
- [✓] Every boundary-crossing flow (DF-1 to DF-12) has at least one threat
- [✓] Top 5 threats mapped to architectural controls
- [✓] Threat Dragon JSON exported to repository